

HW04 — Automation Testing | Báo cáo chính

Sinh viên	23127195
Bài tập	HW04-AI — Automation Testing
SUT	EShop (eshop-sut) — frontend-web :5173 , frontend-admin :5174 , backend API :3000
Repository	https://github.com/hungtmh/HW04-TESTING
Công cụ	Playwright 1.62.1 (Test Runner + HTML Reporter), Node.js 22.20.0
Trình duyệt	Chromium / Firefox (Gecko) / WebKit, 3 engine độc lập
Video demo (Task 2)	https://youtu.be/AR1Z5RGFVRs
Video Agent Skill	https://youtu.be/Vxf9-R9AC54
Ngày thực hiện	2026-08-16

1. Chọn feature

Ba feature giữ nguyên từ HW02, mỗi Pool một feature:

Pool	Mã	Tên feature	Giao diện kiểm thử	Test case
A	FR-01	Đăng ký tài khoản	frontend-web /register	27
B	FR-09	Mã giảm giá	frontend-web /checkout	19
C	FR-14	Quản lý danh mục (CRUD)	frontend-admin :5174	17

2. Tổng kết thực thi

Feature	Test case	Browser	Pass/browser	Fail/browser	Tổng lượt chạy
FR-01	27	3	19	8	81
FR-09	19	3	13	6	57
FR-14	17	3	8	9	51
Tổng	63	9 browser run	120	69	189

Ba engine cho kết quả trùng khớp hoàn toàn ở cả ba feature. Không còn test nào flaky sau các lần sửa mô tả ở mục 6 (kể cả race chỉ lộ trên Firefox, xem R-12).

69 lượt fail chính là 23 test gắn `@bug` chạy trên 3 browser. Tôi kiểm chứng lại bằng một script quét toàn bộ `results.json` : không có bất kỳ test nào fail ngoài nhóm `@bug` .

```
Total executions : 189
Passed           : 120
Failed           : 69
OK - mọi test fail đều được gắn @bug (không có fail ngoài ý muốn)
```

Các test `@bug` được viết theo **đặc tả** (`api_specification.md` , hint hiển thị trên UI, và ngữ nghĩa của chính thông báo lỗi mà hệ thống trả về), không theo hành vi hiện có của mã nguồn. Mỗi test đổ ánh xạ 1-1 tới một bug đã ghi nhận.

3. Môi trường và cách chạy lại

```
npm install
npx playwright install chromium firefox webkit

npm --prefix eshop-sut/backend install
npm --prefix eshop-sut/frontend-web install
npm --prefix eshop-sut/frontend-admin install
npm run sut:seed

# 9 browser run, mỗi run một HTML report riêng
node scripts/run-multibrowser.mjs tests/fr01-register.spec.js
node scripts/run-multibrowser.mjs tests/fr09-coupon.spec.js
node scripts/run-multibrowser.mjs tests/fr14-category.spec.js

node scripts/verify-report-banner.mjs # kiểm chứng "Run by: 23127195"
```

`playwright.config.js` khai báo `webServer` cho backend và frontend-web với `reuseExistingServer: true` . **Riêng frontend-admin (:5174) phải chạy tay** trước khi test FR-14:

```
npm --prefix eshop-sut/frontend-admin run dev
```

Ghi chú về BrowserStack

Yêu cầu " ≥ 3 trình duyệt" được đáp ứng bằng **3 engine thật** khác nhau về bản chất (Blink, Gecko, WebKit), không phải ba vỏ bọc của cùng một engine.

Tài khoản BrowserStack đã có, nhưng để trở bộ test lên grid cần `BROWSERSTACK_USERNAME` và `BROWSERSTACK_ACCESS_KEY` — chưa được cung cấp nên phần này chưa cấu hình. Bộ test đã tách `WEB_BASE_URL` / `API_BASE_URL` / `ADMIN_BASE_URL` qua biến môi trường, nên chuyển sang grid từ xa chỉ cần thay mục `projects` trong config, không phải sửa spec.

4. Kiến trúc bộ test

```
tests/
├─ data/                                ← toàn bộ dữ liệu test, ngoài spec
│   ├── fr01-password-rules.csv         (10 dòng)
│   ├── fr01-register-cases.json
│   ├── fr09-coupon-calculations.csv    (10 dòng)
│   ├── fr09-coupon-cases.json
│   ├── fr14-category-names.csv         (6 dòng)
│   └─ fr14-category-cases.json
├─ pages/                              ← Page Object
│   ├── RegisterPage.js
│   ├── CheckoutPage.js
│   └─ AdminCategoryPage.js
├─ utils/
│   ├── csv.js                         ← đọc CSV/JSON
│   ├── env.js                         ← hằng số + sinh email duy nhất
│   └─ api.js                          ← helper backend dùng chung
├─ fr01-register.spec.js               (27 test case)
├─ fr09-coupon.spec.js                 (19 test case)
├─ fr14-category.spec.js               (17 test case)
└─ fr05-search.spec.js                 (buổi demo Agent Skill, không tính điểm featur
scripts/
├─ run-multibrowser.mjs                ← 1 spec × 3 engine → 3 report
├─ verify-report-banner.mjs            ← chứng minh "Run by: 23127195"
├─ capture-bug-evidence.mjs            ← ảnh bug FR-01
└─ capture-bug-evidence-fr09-fr14.mjs ← ảnh bug FR-09 + FR-14
```

Data-driven: không spec nào chứa mảng/đối tượng dữ liệu test hardcoded. Ba file CSV và ba file JSON cung cấp toàn bộ giá trị đầu vào; spec đọc bằng `readCsv()` / `readJson()` rồi sinh test bằng vòng lặp.

Assertion pattern (yêu cầu ≥ 3 , thực tế 6 mỗi feature)

Mã	Pattern	Ví dụ
P1	Navigation / URL	<code>await expect(page).toHaveURL(/\/login\$/)</code>
P2	Web-first element & text	<code>await expect(errorBox).toBeVisible() / .toContainText(...)</code>
P3	DOM property / giá trị số	<code>expect(Validity).toMatchObject({ valueMissing: true });</code> <code>expect(await readAmount('discount')).toBe(50000)</code>
P4	Back-end API + shape body	<code>expect(res.status).toBe(403); expect(body).toMatchObject(...)</code>
P5	Element count / state	<code>toHaveCount(0), toBeDisabled()</code>
P6	Bất biến & nhất quán chéo tầng	giảm giá không âm; danh sách UI == <code>GET /api/categories</code>

5. Chi tiết từng feature

5.1 FR-01 — Đăng ký tài khoản (27 test case, 19 pass / 8 fail)

Nhóm	Mã	Nội dung	Kết quả
1 — Mật khẩu (CSV)	TC-01 → TC-10	10 kiểu mật khẩu: hợp lệ, quá ngắn, thiếu hoa/thường/số, biên 8 và 7 ký tự	9 pass, TC-02 fail → BUG-01
2 — Happy path	TC-11 → TC-13	Tên tiếng Việt có dấu, email plus-tag, nhiều khoảng trắng	3 pass
3 — Trường bắt buộc	TC-14 → TC-17	Bỏ trống từng ô và toàn bộ form	4 pass
4 — Định dạng email	TC-18 → TC-21	abc , abc@ , @domain.com , a b@domain.com	4 fail → BUG-02
5 — Trùng lặp	TC-22	Email đã tồn tại	fail → BUG-03
6 — Bảo mật	TC-23, TC-24	XSS và SQL injection trong ô Họ Tên	2 pass
7 — Biên	TC-25	Họ Tên 255 ký tự	pass
8 — Lưu trữ	TC-26	Mật khẩu plaintext	fail → BUG-04
9 — Nhất quán UI	TC-27	Hint UI vs luật thực thi	fail → BUG-01

5.2 FR-09 — Mã giảm giá (19 test case, 13 pass / 6 fail)

Nhóm	Mã	Nội dung	Kết quả
1 — Tính toán (CSV)	TC-01 → TC-10	Ma trận 10 case: percent/fixed, biên ngưỡng đơn tối thiểu	6 pass, TC-01/02/03 fail → BUG-07 , TC-07 fail → BUG-08
2 — Mã không hợp lệ	TC-11 → TC-13	Không tồn tại, hết hạn, chỉ khoảng trắng (nút bị disable)	3 pass
2b — Ràng buộc API	TC-19	Gọi thẳng API thiếu trường <code>code</code> phải bị từ chối 400	pass
3 — Chuẩn hoá mã	TC-14	Nhập chữ thường <code>bigbuy</code> → UI tự viết hoa	pass
4 — Giới hạn lượt dùng	TC-15	Dùng hết quota <code>VIP100</code> thì bị từ chối	pass
5 — Lách giới hạn	TC-16	Bỏ <code>user_id</code> để lách quota	fail → BUG-09
6 — Luồng đầy đủ	TC-17	Chọn SP → giỏ hàng → checkout → áp mã → thanh toán	pass
7 — Bất biến	TC-18	Giảm giá không âm, thành tiền ≤ tổng gốc	fail → BUG-07

Ghi chú thiết kế: giỏ hàng của SUT là state React thuần, không lưu trữ, nên `page.goto()` sẽ xoá sạch. TC-17 vì vậy điều hướng bằng **click** (client-side routing giữ nguyên provider); các test tính toán còn lại vào thẳng `/checkout` và điều khiển ô "Tổng tiền thanh toán" — công thức giảm giá chỉ phụ thuộc giá trị này.

5.3 FR-14 — Quản lý danh mục (17 test case, 8 pass / 9 fail)

Nhóm	Mã	Nội dung	Kết quả
1 — Tạo (CSV)	TC-01 → TC-06	Tên thường, tiếng Việt, ký tự đặc biệt, 255 ký tự, rỗng, toàn khoảng trắng	4 pass, TC-05/TC-06 fail → BUG-10
2 — Đọc	TC-07	Bảng trên UI khớp <code>GET /api/categories</code>	pass
3 — Sửa	TC-08	UI phải có chức năng Sửa	fail → BUG-14
	TC-09	Đổi tên qua API	pass
	TC-10	Sửa <code>id</code> không tồn tại phải 404	fail → BUG-12
4 — Xoá	TC-11	Xoá trên giao diện	pass
	TC-12	Xoá <code>id</code> không tồn tại phải 404	fail → BUG-12
	TC-13	Không được xoá danh mục đang có sản phẩm	fail → BUG-13
5 — Phân quyền	TC-14 → TC-16	User thường tạo/sửa/xoá danh mục	3 fail → BUG-11
	TC-17	Không có token phải 401	pass

Test case chưa tự động hoá được

Nội dung	Feature	Lý do
Xác minh email kích hoạt tài khoản	FR-01	SUT không có luồng gửi/xác minh email, không có mail server để hứng thư
CAPTCHA / rate limiting khi đăng ký hàng loạt	FR-01	SUT không triển khai cơ chế này
Strength meter mật khẩu theo thời gian thực	FR-01	Giao diện không có
Mã giảm giá dùng chung nhiều người (<code>max_uses</code> toàn cục)	FR-09	Schema chỉ có <code>max_uses_per_user</code> , không có tổng lượt dùng
Sửa danh mục qua giao diện	FR-14	Chức năng không tồn tại (BUG-14) — chỉ kiểm chứng được sự vắng mặt
Kéo-thả sắp xếp thứ tự danh mục	FR-14	Không có trong SUT

6. Human review — AI đã sai/thiếu ở đâu

Đây là phần trọng tâm. **13 phát hiện**, trong đó **5 lỗi khiến test cho kết quả sai lệch** (xanh giả hoặc đỏ sai lý do). Hai phát hiện cuối (R-12, R-13) đến từ đợt hoàn thiện sau khi đã đóng gói xong ba feature.

R-01 — Selector `getByLabel()` trả về 0 phần tử (FR-01)

AI sinh ra: `page.getByLabel('Họ Tên').fill(...)`

Thực tế: `Register.jsx` render `<label>` không có `htmlFor` và `<input>` không có `id / name`. Probe cho kết quả `count=0` ở cả 3 trường.

Đã sửa: neo vào `<div>` bọc trường rồi lấy `<input>` bên trong.

Vì sao AI sai: mô hình mặc định giả định form đúng chuẩn accessibility; prompt ban đầu mô tả feature bằng lời, không đính kèm DOM thật.

R-02 — Assert vào message validation của trình duyệt (FR-01)

Chuỗi này khác nhau giữa Chromium/Firefox/WebKit và đổi theo ngôn ngữ hệ điều hành. **Đã sửa:** assert vào Constraint Validation API (`validity.valueMissing`).

R-03 — Assertion "chạy trước" khiến 4 test PASS GIẢ ⚠️ (FR-01)

AI sinh ra: chứng minh "tài khoản không được tạo" bằng `await expect(page).toHaveURL(/\\/register$/)` ngay sau khi bấm nút.

Thực tế: ngay sau `click()`, SPA chưa resolve xong `POST /api/register`, nên URL vẫn là `/register` **bất kể server quyết định gì**. TC-18 → TC-21 báo xanh trên một SUT đang chấp nhận email rác — **bộ test che giấu chính BUG-02**.

Đã sửa: hỏi thẳng backend còn bao nhiêu dòng `users` mang email đó.

Vì sao AI sai: lỗi *thứ tự thời gian*, không phải cú pháp — code chạy được, test xanh, không tín hiệu nào cảnh báo.

R-04 — `waitForTimeout()` cứng (FR-01)

Đã sửa: dùng web-first assertion thay vì chờ theo đồng hồ.

R-05 — Race giữa lời gọi API và request của SPA, chỉ lộ trên WebKit (FR-01)

TC-23 vô tình che được vì có thêm `page.evaluate()` tạo độ trễ; TC-24 không có nên fail **chỉ trên WebKit**. **Đã sửa:** chờ `toHaveURL(/\/login$/)` trước khi gọi API. Đây là lỗi của **bộ test**, không phải SUT, và chỉ lộ ra nhờ yêu cầu chạy đa trình duyệt.

R-06 — Dữ liệu test hardcoded trong spec

Đề bài cấm. **Đã sửa:** tách toàn bộ sang 6 file CSV/JSON.

R-07 — AI mô tả lại hành vi đang có thay vì hành vi đặc tả

Khi được đưa mã nguồn, AI đề xuất case "*mật khẩu Password123! → kỳ vọng bị từ chối*" vì đọc regex thấy vậy. Test kiểu đó **luôn xanh và không bao giờ tìm ra lỗi** — nó biến bug thành đặc tả. Người review phải chủ động đối chiếu với `api_specification.md` và hint trên UI.

Đây là lý do 23 test **cố ý fail**, thay vì được "nới" cho xanh.

R-08 — Năm test đỏ vì SAI LÝ DO ⚠️ (FR-01)

Sau khi sửa R-03, bộ test cho 19 pass / 8 fail — con số **trùng khớp** kỳ vọng. Nhưng đọc kỹ message thì 5/8 test fail với `admin login must succeed to inspect user rows`, tức đỏ vì **helper hỏng**, không phải vì BUG-02/BUG-03.

Truy nguyên: helper đăng nhập admin bằng `admin123` lấy từ `setup_guide.md`, trong khi seed thực tế ghi `Admin123!` (BUG-06). FR-02 cộng `login_attempts + 2` với ngưỡng khoá 3, nên **2 lần thử sai đã khoá admin 180 giây**, và trong lúc khoá hệ thống kiểm tra khoá *trước* khi so mật khẩu.

Đã sửa: lấy mật khẩu từ **seed script (nguồn chân lý)**; cache token; thêm status + body vào message assertion để lần sau lỗi tự nói ra nguyên nhân.

Bài học: con số pass/fail không đủ để kết luận — **phải đọc lý do test đỏ**.

R-09 — Hai lỗi phân tích số tiền trong Page Object của FR-09 ⚠️

Hàm `readAmount()` bóc số tiền từ chuỗi hiển thị. Bản đầu vừa bắt dấu trừ trong regex **vừa** nhân `-1`, khiến `-4.500.000` bị khử dấu thành `+4.500.000` — con số sai này suýt được đưa vào bug report.

Khi sửa lỗi trên, tôi lại bỏ dấu phẩy khỏi character class. Playwright để locale mặc định **en-US**, nên trang render `50,000` chứ không phải `50.000`; regex tách thành `50` và `000` rồi lấy phần cuối → **kết quả 0**. Hồi quy này làm 6 test đang xanh chuyển đỏ ở lần chạy đa trình duyệt.

Đã sửa: chấp nhận cả `.` và `,` trong match, strip cả hai, không nhân dấu.

Bài học: một bản vá cũng cần được kiểm chứng lại đầy đủ như mã gốc — sửa lỗi A mà không chạy lại toàn bộ thì rất dễ tạo ra lỗi B.

R-10 — Selector đăng nhập admin sai hoàn toàn (FR-14)

AI sinh ra: `input[type="email"]`, nút `Đăng nhập`.

Thực tế: ô email của `frontend-admin` **không có thuộc tính** `type`, chỉ có `placeholder="Email"`; nút ghi `Login`. 8 test UI timeout hàng loạt.

Đã sửa: dùng `getByPlaceholder`, `getByRole('button', { name: 'Login' })`, và neo tab bằng `li` khớp chính xác `/^Danh mục$/` để không đụng phải tiêu đề "Quản lý Danh mục" hay cột "Tên Danh Mục".

Vì sao AI sai: cùng nguyên nhân R-01 — suy diễn theo form chuẩn thay vì theo mã nguồn thật. Lặp lại đúng sai lầm cũ trên một màn hình khác.

R-11 — Test tự đầu độc dữ liệu của nhau ⚠️ (FR-14)

Các test kỳ vọng "thao tác này phải bị từ chối" chỉ dọn dẹp ở nhánh thành công. Nhưng đúng lúc chúng **bắt được bug**, thao tác lại thành công và để lại dòng rác. Sau vài test, bảng danh mục đầy `""`, `null`, `"Hacked By User"` ... và TC-07 (so khớp UI với backend) fail vì đồng rác đó chứ không vì lỗi nó nhầm tới.

TC-07 còn phụ thuộc vào danh mục seed `"Điện thoại"` — thứ mà chính các test xóa hợp lệ có thể loại bỏ, khiến kết quả phụ thuộc thứ tự chạy.

Đã sửa: hàm `cleanupAdded()` so sánh danh sách trước/sau và xóa mọi dòng phát sinh **bất kể test pass hay fail**; TC-07 tự tạo danh mục riêng để kiểm chứng thay vì dựa vào dữ liệu seed.

Bài học: test âm tính phải dọn dẹp ở **cả hai** nhánh — nếu không, mỗi lần bắt được bug là một lần làm bẩn môi trường cho test sau.

R-12 — Race dựng lại bảng, chỉ thua trên Firefox (FR-14) ⚠️

Khi bổ sung một chút cho bộ test rồi chạy lại toàn bộ ma trận, TC-02 ("tạo danh mục tên tiếng Việt có dấu") đột nhiên fail **chỉ trên Firefox** (7/10 thay vì 8/9), còn Chromium và WebKit vẫn xanh. Đây là một test *phải pass*, nên con số lệch đó là tín hiệu phải truy tới cùng.

Nguyên nhân: sau khi bấm "Thêm mới", test đọc ngay bảng danh mục trên UI, nhưng React chưa kịp render dòng vừa thêm. Chromium/WebKit tình cờ render đủ nhanh nên qua được, Firefox chậm hơn một nhịp nên đọc phải bảng cũ. Bản thân dữ liệu ở backend đã đúng (assertion `after == before + 1` vẫn pass), chỉ có phần đọc UI bị đọc hớ.

Đã sửa: chờ dòng mới thật sự hiện ra (`await expect(rowByName(name)).toBeVisible()`) rồi mới đọc bảng, thay vì đọc ngay. Sau khi sửa, Firefox chạy lại nhiều lần đều ổn định 8/9 như hai engine kia.

Bài học: giống R-05, một race trong *bộ test* chỉ chịu lộ mặt khi chạy đủ ba engine; nếu chỉ chạy một trình duyệt thì đã tưởng là ổn.

R-13 — Chọn sai payload XSS tạo ra âm tính giả (buổi demo FR-05) ⚠️

Khi dùng Agent Skill trên FR-05 để kiểm tra XSS ở ô tìm kiếm, bản nháp đầu định thử payload `<svg onload=...>`. Probe cho thấy payload này **không chạy**: trình duyệt không kích hoạt `onload` của `<svg>` khi node được chèn bằng `innerHTML`. Nếu tin vào kết quả đó, test sẽ **xanh** và kết luận "không có XSS", trong khi lỗ hổng vẫn nằm nguyên tại chỗ.

Chỉ payload `<img src=x onerror=...>` mới thực sự thực thi khi chèn qua `innerHTML`. Đổi sang payload này, cờ `window.__xss` bật lên đúng như dự đoán và lỗ hổng phản chiếu (reflected XSS) hiện ra rõ ràng.

Bài học: với test bảo mật, một cái xanh không chứng minh phần mềm an toàn — nó có thể chỉ chứng minh mình đã chọn nhầm cách tấn công. Phải probe để biết payload nào thật sự chạy trước khi tin vào kết quả.

7. Bug phát hiện được

15 bug, chi tiết đầy đủ (steps to reproduce, expected/actual, ảnh) trong `../bug-report/BUG_REPORT.md` và trên [GitHub Issues](#).

ID	Feature	Mức độ	Tóm tắt
BUG-01	FR-01	High	Luật mật khẩu bắt buộc khoảng trắng, cấm ký tự đặc biệt
BUG-02	FR-01	High	Không validate định dạng email
BUG-03	FR-01	Critical	Email trùng tạo được nhiều tài khoản
BUG-04	FR-01	Critical	Mật khẩu plaintext, bị trả về trong response login
BUG-05	FR-12*	High	GET /api/admin/users không kiểm tra role
BUG-06	Tài liệu	Low	setup_guide.md ghi sai mật khẩu admin
BUG-07	FR-09	Critical	Công thức % bị đảo — khách bị tính gấp 10 lần
BUG-08	FR-09	Medium	Ngưỡng đơn tối thiểu loại trừ giá trị bằng ngưỡng
BUG-09	FR-09	High	Bỏ user_id là lách được giới hạn lượt dùng
BUG-10	FR-14	Medium	Tên danh mục rỗng/ null vẫn tạo được
BUG-11	FR-14	Critical	User thường toàn quyền CRUD danh mục
BUG-12	FR-14	Medium	Sửa/xoá id không tồn tại vẫn báo 200
BUG-13	FR-14	High	Xoá danh mục có sản phẩm làm sản phẩm mờ côi
BUG-14	FR-14	High	Giao diện danh mục thiếu hoàn toàn chức năng Sửa
BUG-15	FR-13*	Medium	Dashboard nhân đôi doanh thu đơn đã giao

* ngoài ba feature được giao, phát hiện tình cờ.

Bug nghiêm trọng nhất — BUG-07: đơn 500.000 đ áp mã giảm 10% cho ra Tiết kiệm: -4,500,000 đ và Thành tiền: 5,000,000 đ, trong khi giao diện vẫn hiện  "Áp dụng thành công! Giảm 10%". Nguyên nhân: $total \times (1 - discount_value)$ thay vì $total \times discount_value / 100$.

8. Đối chiếu yêu cầu đề bài

Tiêu chí	Yêu cầu	Đạt được
Số feature	3 (mỗi Pool 1)	3 ✓
Test case / feature	≥ 12	27 / 19 / 17 ✓
Dữ liệu tách file riêng	.csv hoặc .json	3 CSV + 3 JSON ✓
Assertion pattern	≥ 3	6 ✓
Browser	≥ 3	3 engine ✓
Browser run	≥ 9	9 ✓
HTML report có Run by: + ISO	bắt buộc	9/9 report, có ảnh kiểm chứng ✓
Review & phân tích lỗi AI	bắt buộc	13 phát hiện R-01 → R-13 ✓
Bug report + GitHub Issues	nếu có	15 bug, 15 issue kèm ảnh ✓
Commit chạm file .spec.js	≥ 8	đạt (xem evidence/git-commit-log-files.txt)

9. Video và Agent Skill

- **Video demo (Task 2):** <https://youtu.be/AR1Z5RGFVRs> — đi qua kiến trúc bộ test, chạy 3 engine, mở HTML report có Run by: 23127195, và tái hiện tay BUG-07 trên giao diện.
- **Video Agent Skill:** <https://youtu.be/Vxf9-R9AC54> — dùng skill eshop-automation trên một feature mới (FR-05) và để nó tự tìm ra reflected XSS + SQL injection ở ô tìm kiếm. Xem thêm ../agent-skill/AGENT_SKILL.md.

Cả hai video đều để Unlisted, nói tiếng Việt và quay kèm face-cam.